Processo de Segregação de Funções de TI

Documento de Especificação (Procedimento)

Ref. COBIT® – PO4.11

Índice

1. OBJETIVO 3
2. ESCOPO DO PROCESSO 3
3. OBJETIVOS DE CONTROLE COBIT 4.1 3
4. CONCEITOS 3
5. DIRETRIZES E DEFINIÇÕES DO PROCESSO 4
6. INTERFACE COM OUTROS PROCESSOS 4
7. FLUXOGRAMA 5
8. DESCRIÇÃO DAS ATIVIDADES DO FLUXOGRAMA 6
9. MATRIZ RACI 8
10. PAPÉIS E RESPONSABILIDADES 8
11. INDICADORES 9
12. DOCUMENTOS RELACIONADOS 9
13. CONTROLE DE VERSÃO 10

1. Objetivo

Estabelecer princípios que governem e enderecem a Segregação de Funções, de forma a assegurar que uma única função/papel não possa corromper atividades críticas de um processo ou realizar o próprio processo fim-a-fim, ainda que de forma acidental ou deliberada. Desta forma, os conflitos de função são identificados, mitigados ou eliminados.

2. Escopo do Processo

O escopo do processo de Gestão de Segregação de Funções de TI cobre os processos de gerenciamento da Área de TI – Tecnologia da Informação da Smiles.

3. Objetivos de Controle COBIT 4.1

Processo / Objetivos de Controle	Situação	Análise sobre o processo atual
PO4 - Definir os Processos, a Organização e os Relacionamentos de TI		
PO4.11 - Segregação de Funções Implementar uma separação de papéis e responsabilidades que reduza a possibilidade de um único indivíduo subverter um processo crítico. A gerência também deve se certificar de que o pessoal esteja executando apenas tarefas autorizadas relevantes aos seus respectivos cargos e posições.	**Contemplado**	Procedimento formal para gerenciamento da Segregação de Funções em TI está estabelecido por este processo.

4. Conceitos

Os principais conceitos referentes ao processo de Gestão de Segregação de Funções de TI são:

- **Segregação de Funções**: princípio básico de controle interno, essencial para a sua efetividade. Consiste na separação de atribuições ou responsabilidades entre diferentes funções/papéis, especialmente relacionado e aplicado às funções e atividades-chave de autorização/aprovação, execução, validação/conferência ou auditoria. Também conhecido por Segregation of Duties ou simplesmente pela sigla SoD.

- **Processo:** conjunto estruturado de atividades destinadas a atingir um objetivo específico. Um processo tem uma ou mais entradas definidas e as transforma em saídas definidas.

- **Papel:** Um conjunto de procedimentos ou ações conectadas que são realizadas por uma pessoa, equipe ou grupo em um contexto específico.

- **Atividade do Processo:** equivale à realização/concretização de uma tarefa. De forma agrupada, refere-se ao conjunto de ações para atingir um resultado específico, normalmente definidas como parte de processos e documentadas em procedimentos.

- **Atividade Crítica de Processo:** equivale a uma tarefa de alta relevância/importância para o atingimento dos resultados de um processo.

- **Dono do Processo:** equivale a um papel exercido por um Colaborador Smiles com pleno conhecimento das atividades e funções exercidas em um determinado processo de gestão.

5. Diretrizes e Definições do Processo

O processo de Gestão de Segregação de Funções de TI possui as seguintes diretrizes e definições:

- **Definição única de Processo**: haverá apenas um único processo de Gestão de Segregação de Funções de TI para a Smiles.

- **Política de Segregação de Funções de TI:** documento que define, direciona os princípios de Segregação de Funções de TI a serem aplicados através deste processo.

- **Classificação de Atividades:** classificação aplicada às atividades dos processos selecionados para avaliação de segregação de funções, a qual indica, para cada atividade, uma das seguintes opções:

    - **"Executa"**: serão classificadas desta forma, as atividades relacionadas à realização / execução propriamente dita de tarefas do processo.

    - **"Aprova"**: serão classificadas desta forma, as atividades de aprovação/autorização (tomada de decisão) do processo.

    - **"Valida"**: serão classificadas desta forma, as atividades de checagem ou conferência de tarefas anteriores do processo.

- **Avaliação de Atividades Críticas:** resultado do entendimento do Dono do Processo em relação às atividades mais relevantes/importantes do processo em questão. Deverão ser indicadas pelo Dono do Processo no momento da identificação dos potenciais conflitos envolvendo as mesmas.

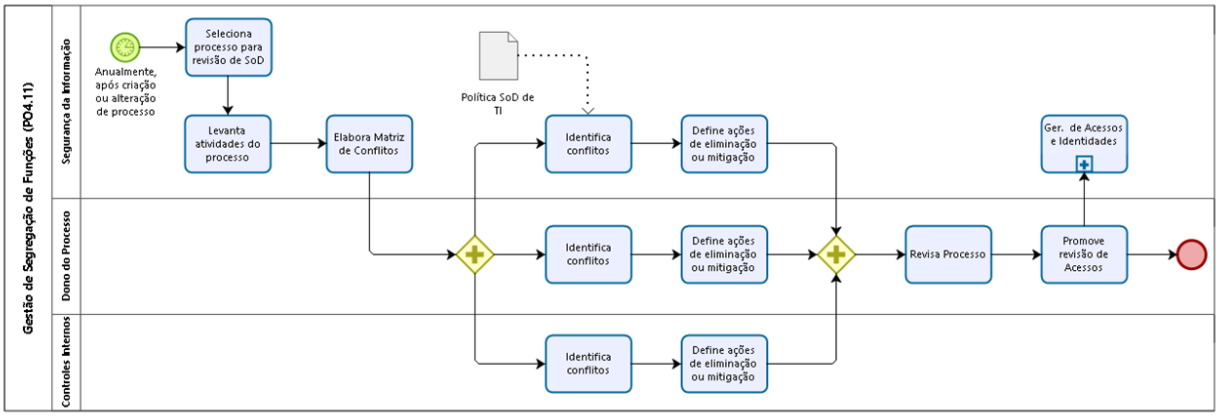
6. Interface com outros processos

- **Gerenciamento de Acessos e Identidades**

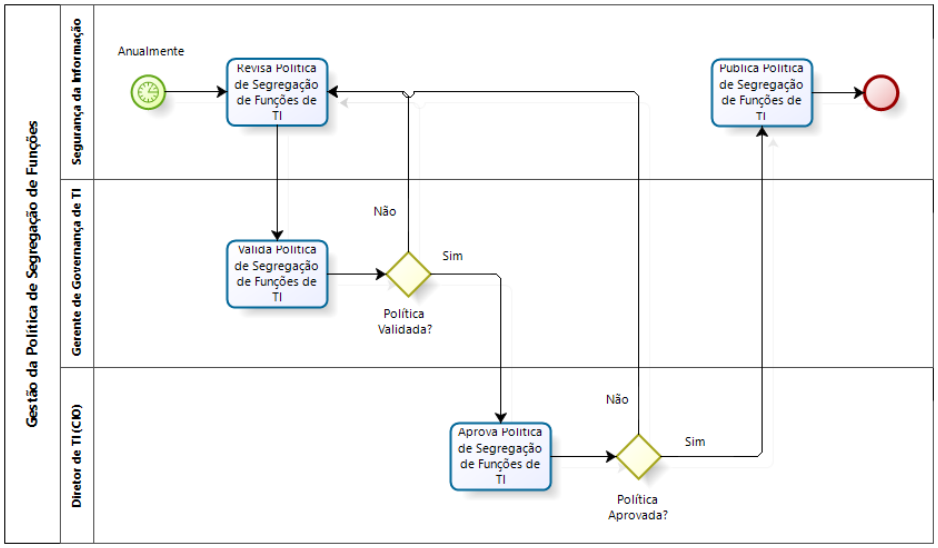
    - O processo de Gestão de Segregação de Funções em TI promoverá revisões de acessos nos Sistemas de Informação que suportam os processos avaliados.

7. Fluxograma

7.1 Fluxo de Gestão de Segregação de Funções



7.2 Fluxo de Gestão da Política de Segregação de Funções



8. Descrição das Atividades do Fluxograma

8.1 – Atividades de Gestão de Segregação de Funções

Passo	Atividade	Executor	Descrição	Passo Seguinte
01	Seleciona Processo para revisão de SoD	Segurança da Informação	Nesta atividade, a equipe de Segurança da Informação seleciona Processo para revisão de SoD. Anualmente, após criação ou alteração de processo, a equipe de Segurança da Informação Seleciona Processo para revisão de SoD e solicita ao Dono do Processo a Levantamento das atividades.	02
02	Levanta Atividades do Processo	Segurança da Informação	Nesta atividade, a equipe de Segurança da Informação levanta as atividades do processo. Após seleção do Processo para revisão de SoD, a equipe de Segurança da Informação levanta / identifica as suas respectivas atividades na documentação do processo selecionado.	03
03	Elabora Matriz de Conflitos	Segurança da Informação	Nesta atividade, a equipe de Segurança da Informação elabora a Matriz de Conflitos. Após o levantamento de atividades do processo, a equipe de Segurança da Informação elabora (produz) a Matriz de Conflitos para posterior análise de conflitos.	04
04	Identifica Conflitos	Segurança da Informação, Dono do Processo e Controles Internos	Nesta atividade, a equipe de Segurança da Informação, o Dono do Processo e equipe de Controles Internos identificam Conflitos na Matriz de Conflitos elaborada. Após elaboração da Matriz de Conflitos, a equipe de Segurança da Informação, o Dono do Processo e equipe de Controles Internos realização a atividade de identificação de Conflitos de Segregação de Funções, primeiramente avaliando o cruzamento entre as atividades do processo e as suas funções/papéis e posteriormente avaliando o cruzamento entre as funções/papéis do processo e os recursos/cargos relacionados, conforme as diretrizes da Política de Segregação de Funções de TI.	05
05	Define Ações de Eliminação ou Mitigação	Segurança da Informação, Dono do Processo e Controles Internos	Nesta atividade, a equipe de Segurança da Informação, o Dono do Processo e equipe de Controles Internos definem ações de eliminação ou mitigação dos conflitos identificados. Após identificação de conflitos de Segregação de Funções, a equipe de Segurança da Informação, o Dono do Processo e equipe de Controles Internos definem as ações de eliminação ou mitigação de Conflitos de Segregação de Funções, conforme as diretrizes da Política de Segregação de Funções de TI.	06
06	Revisa Processo	Dono do Processo	Nesta atividade, o Dono do Processo revisa o processo em questão, contemplando as ações de eliminação ou mitigação definidas. Após a definição de ações para eliminação ou mitigação de conflitos de Segregação de Funções, o Dono do Processo realiza a revisão do processo em questão contemplando as ações de eliminação ou mitigação definidas.	07
07	Promove Revisão de Acessos	Dono do Processo	Nesta atividade, o Dono do Processo promove a revisão de acessos. Após revisão do Processo, o Dono do Processo realiza comunicação com os responsáveis pelo processo de Gerenciamento de Acessos e Identidades, para que seja realizada uma revisão de acessos no(s) sistema(s) de informação que suportam o processo em questão.	Fim

8.2 Atividades de Revisão da Política de Segregação de Funções

Passo	Atividade	Executor	Descrição	Passo Seguinte
01	Revisa Política de Segregação de Funções de TI	Segurança da Informação	Nesta atividade, a equipe de Segurança da Informação revisa a Política de Segregação de Funções de TI. Anualmente a equipe de Segurança da Informação Revisa a Política de Segregação de Funções avaliando a aplicabilidade dos seus princípios e controles compensatórios no contexto atual (da época) para a Smiles.	02
02	Valida Política de Segregação de Funções de TI	Gerente de Governança de TI	Nesta atividade, o Gerente de Governança de TI valida a Política de Segregação de Funções de TI. Após a revisão da Política de Segregação de Funções de TI, o Gerente de Governança de TI realiza a validação da mesma. Caso não concorde com a revisão elaborada, encaminha considerações para nova revisão pela equipe de Segurança da Informação. (Segue para passo 01) Caso concorde com a revisão elaborada, encaminha para aprovação do Diretor de TI. (Segue para passo 03)	01 ou 03
03	Aprova Política de Segregação de Funções de TI	Diretor de TI	Nesta atividade, o Diretor de TI aprova a Política de Segregação de Funções de TI. Após validação da política pelo Gerente de Governança de TI, o Diretor de TI realiza a aprovação da Política de Segregação de Funções de TI. Caso não aprove a política, encaminha para nova revisão pela equipe de Segurança da Informação. (Segue para passo 01) Caso aprove a política, encaminha para publicação pela equipe de Segurança da Informação. (Segue para passo 04)	01 ou 04
04	Publica Política de Segregação de Funções de TI	Segurança da Informação	Nesta atividade a equipe de Segurança da Informação publica a Política de Segregação de Funções de TI. Após a aprovação do Diretor de TI, a equipe de Segurança da Informação publica a Política de Segregação de Funções de TI no repositório oficial de documentação da Smiles.	Fim

9. Matriz RACI

Matriz RACI Smiles	Gestão de Segregação de Funções de TI R = Responsible | A = Accountable | C = Consulted | I = Informed Executor | Principal Responsável | Consultado | Informado	CIO / Diretor de TI	Segurança da Informação	Dono do Processo	Controles Internos
Atividade	Atividades				
	Responsável pelo sucesso do processo	**A**			
01	Seleciona Processo para revisão de SoD		R	I	
02	Levanta Atividades do Processo		R		
03	Elabora Matriz de Conflitos		R		
04	Identifica Conflitos		R/C	R	R/C
05	Define Ações de Eliminação ou Mitigação		R/C	R	R/C
06	Revisa Processo		C	R	C
07	Promove Revisão de Acessos			R	

Matriz RACI Smiles	Gestão da Política de Segregação de Funções de TI R = Responsible | A = Accountable | C = Consulted | I = Informed Executor | Principal Responsável | Consultado | Informado	CIO / Diretor de TI	Segurança da Informação	Gerente de Governança de TI
Atividade	Atividades			
	Responsável pelo sucesso do processo	**A**		
01	Revisa Política de Segregação de Funções de TI		R	
02	Valida Política de Segregação de Funções de TI		I	R
03	Aprova Política de Segregação de Funções de TI	R		C
04	Publica Política de Segregação de Funções de TI		R	

10. Papéis e Responsabilidades

- **Segurança da Informação**
  - Selecionar processos para revisão de SoD (segregação de funções).
  - Elaborar a Matriz de Conflitos de Segregação de Funções.
  - Contribuir com a identificação dos conflitos de atividades e de funções/papéis, incluindo definição de ações para eliminação ou mitigação dos referidos conflitos
  - Revisar a Política de Segregação de Funções de TI.
- **Dono do Processo**
  - Identificar as atividades críticas do processo pelo qual é dono, para aplicação da segregação de função sobre as mesmas.

- Identificar conflitos de atividades e de funções/papéis, incluindo definição de ações para eliminação ou mitigação dos referidos conflitos
- Responsável pela revisão do processo, incluindo as ações de eliminação ou mitigação dos conflitos identificados.
- Responsável pela promoção da revisão de acessos (gatilho para o processo de Gerenciamento de Acessos e Identidades).

- **Controles Internos**
  - Contribuir com a identificação dos conflitos de atividades e de funções/papéis, incluindo definição de ações para eliminação ou mitigação dos referidos conflitos

- **Gerente de Governança de TI**
  - Validar a Política de Segregação de Funções de TI

- **Diretor de TI (CIO)**
  - Aprovar a Política de Segregação de Funções de TI
  - Principal responsável pelo resultado do processo.

11. Indicadores

O processo de Gestão da Segregação de Funções em TI possui a definição de um Indicador de Desempenho para acompanhamento de sua evolução, conforme demonstrado abaixo:

- Percentual e Quantidade de Processos de TI revisados / total de processos de TI documentados (Indicador Trimestral).

12. Documentos Relacionados

- CobiT® v4.1 (Control Objectives for Information and related Technology)
- ISO/IEC 27001 (Information Security Management Systems - Requirements)
- ISO/IEC 27002 (Code of Practice for Information Security Management)
- Política de Segregação de Funções de TI
- Matriz de Conflitos de Segregação de Funções (template)

13. Controle de Versão

Versão	Data	Responsável	Principais Alterações
1.0	25/04/2017	CHACON Consultoria	Primeira versão do documento.